

Hallazgos de análisis externo — ERSO 2026-006

- [Hallazgos de análisis externo — ERSO 2026-006](#)
 - [Publicación del DID Document institucional](#)
 - [1. Resumen](#)
 - [2. Proyectos citados en este informe](#)
 - [3. Hallazgos](#)
 - [4. Aplicación a los criterios de aceptación de la ERSO 006](#)
 - [5. Diferencias de diseño frente a nuestro proyecto](#)
 - [6. Qué aprender y qué hacer con esto](#)
 - [7. Límites de este informe](#)

Hallazgos de análisis externo — ERSO 2026-006

Publicación del DID Document institucional

Proyecto propio	Identidad Digital Soberana SSI (/home/geovani/Descargas/generic/bitacora/new_proyect)
Fecha del análisis	2 de octubre de 2026
Carpetas analizadas	/home/geovani/Workspace/Wallet/Wallet, ../Verifier, ../Issuer, ../Trust, ../librerias
Versión del informe	Actualizado el 2 de octubre de 2026: se añaden los hallazgos de la carpeta librerias y el análisis a fondo del gestor de listas de confianza
Cobertura de esta ERSO	Por analogía (registro de entidades, listas de confianza y certificados de registro)
Método	Lectura de código y documentación; no se compiló ni se ejecutó ninguno de los proyectos externos

1. Resumen

La ERSO 006 trata de que una **entidad institucional publique su identidad con escritura autenticada, espacio propio y lectura pública separada**. El único VDR externo (`av-app-android-wallet-ui`) **no autentica** las escrituras. El patrón de "cada entidad con su alcance y publicación autenticada" sí aparece, pero con otro mecanismo (certificados y listas firmadas), en el registro de entidades (`Issuer` y `Trust/eudi-srv-web-relyingparty-registration-py`) y en el gestor de listas de confianza (`Trust/eudi-srv-web-trustedlist-manager-py`). **Complemento:** (1) análisis a fondo del **gestor de listas de confianza** (`Trust/eudi-srv-web-trustedlist-manager-py`) y (2) hallazgos de la carpeta `librerias`: la cartera valida el **certificado de registro del verificador**, y las bibliotecas de OpenID4VP identifican al verificador por DID, X.509 o attestation.

2. Proyectos citados en este informe

Carpeta	Proyecto	Qué es
Wallet	<code>av-app-android-wallet-ui</code>	App Android de verificación de edad (versión derivada de la anterior); incluye el módulo <code>vdr-extension-logic</code>
Issuer / Trust	<code>eudi-srv-web-relyingparty-registration-py</code>	Registro de entidades verificadoras y emisión de sus certificados (idéntico en Issuer y en Trust)
Trust	<code>eudi-srv-web-trustedlist-manager-py</code>	Gestor de Listas de Confianza (Python)
Issuer	<code>eudi-srv-pid-issuer</code>	Emisor de credenciales (Kotlin/Spring)
Verifier	<code>eudi-wallet-rfcs</code>	Especificaciones EWC (RFC 001 a 013)
librerias	<code>eudi-lib-android-wallet-core</code>	Biblioteca Android de la cartera EUDI: claves, documentos, confianza, estado, registro de transacciones
librerias	<code>eudi-lib-jvm-openid4vp-kt</code>	Biblioteca de OpenID4VP (autenticación del verificador, cifrado de respuesta, DID)

3. Hallazgos

La columna *Criterio* indica a qué criterio de aceptación de la ERSO se aplica el hallazgo (el detalle está en la sección 4).

#	Proyecto (carpeta/proyecto)	Archivo o lugar	Qué se encontró	Relación con nuestro proyecto	Criterio
1	Wallet/av-app- android-wallet-ui	vdr-extension-logic/.../routes/VdrRoutes.kt	Sin autenticación ni mTLS en ninguna ruta de escritura (POST y PUT /vdr/v1/identifiers , /backup , /restore).	Es precisamente lo que añade la ERSO 006: canal de escritura autenticado y limitado al espacio de la entidad.	C2
2	Issuer y Trust/eudi-srv-web-relyingparty-registration-py	workflow_and_endpoints.md y README.md	Alta en cadena: ley → persona → entidad legal → proveedor → relying party → uso previsto → credencial. Emite un certificado de acceso (WRPAC, ETSI TS 119 411-8) y uno de registro (WRPRC, ETSI TS 119 475) en P12, JWT y CBOR.	Análogo a nuestras cuentas, espacios reservados y certificado de entidad; la identidad es un certificado emitido por una CA (EJBCA), no un DID publicado.	C2
3	Issuer y Trust/eudi-srv-web-relyingparty-registration-py	app/RPR_routes.py (/authentication , /pid_authorization , /getpidoid4vp)	El usuario se autentica presentando su credencial (PID) por OpenID4VP antes de gestionar entidades.	Autenticación fuerte del que escribe; nosotros usamos certificado cliente, secreto de servicio y prueba de posesión.	C2
4	Trust/eudi-srv-web-trustedlist-manager-py	app/RPR_routes.py (/menu_tsl , /menu_lotl , /tsl/create , /tsl/xml , /download , /validate_xml)	Roles con alcance: operador de TSL (Estado miembro) y operador de LoTL (Comisión). Crean, firman, publican y validan listas.	Equivale a nuestro "cada entidad escribe solo en su espacio".	C2
5	Trust/eudi-srv-web-trustedlist-manager-py	README.md	Las listas contienen los anclajes de confianza; la presencia en la lista es lo que acredita la confianza.	Nuestra confianza en el emisor viene de su DID Document en un espacio reservado, no de una lista firmada.	C1

#	Proyecto (carpeta/proyecto)	Archivo o lugar	Qué se encontró	Relación con nuestro proyecto	Criterio
6	Issuer/eudi-srv-pid-issuer	src/main/kotlin/.../adapter/out/IssuerSigningKey.kt (línea ~41)	La clave del emisor debe tener cadena x5c de certificados.	El emisor se identifica por certificado; en nuestro proyecto, por DID (ERSo 006).	C1
7	Verifier/eudi-wallet-rfcs	ewc-rfc012-trust-mechanism.md	Contempla x5c y kid/DID para identificar a un proveedor, y el estado granted/withdrawn en la lista de confianza.	Respalda que el DID es una alternativa válida del ecosistema.	C1
8	Trust/eudi-srv-web-trustedlist-manager-py	app/xml_gen/xmlGen.py (xml_gen_xml , líneas ~456 a 483) y app/app_config/config.py	La lista se firma con XAdES envuelta (ECDSA-SHA256, c14n 2001) usando el certificado y la clave privada cargados de archivos del servidor (cert_UT , priv_key_UT), no la del usuario conectado.	Contraste: la autoridad que firma es el servicio; en nuestro registro cada escritura la autoriza la clave del propio DID.	C2
9	Trust/eudi-srv-web-trustedlist-manager-py	app/RPR_routes.py (/tsl/xml , /download , /validate_xml) y app/xml_gen/xmlGen.py (xml_validator)	Genera el XML, muestra el hash SHA-256 previo a la firma y la huella del certificado, lo entrega para descarga y lo valida contra el esquema XSD de ETSI 119 612.	Evidencia parcial de publicación (hash y huella), pero sin versión ni URL registradas.	C4
10	Trust/eudi-srv-web-trustedlist-manager-py	app/xml_gen/xmlGen.py (schemeInfo.TSLSequenceNumber = ...+1)	El número de secuencia del XML es el de la base más uno; no se encontró una instrucción que lo actualice en la base tras generar.	Posible límite: dos generaciones seguidas darían el mismo número; nuestro registro incrementa la versión dentro de la transacción de escritura.	C4 (límite)
11	Trust/eudi-srv-web-trustedlist-manager-py	app/RPR_routes.py y app/app_config/config.py (roles : tsp_op , tsl_op , lotl_op)	Tres roles con alcance distinto; la autenticación es con la credencial PID presentada por OpenID4VP.	Alcance por rol equivale a nuestro alcance por espacio de entidad.	C2

#	Proyecto (carpeta/proyecto)	Archivo o lugar	Qué se encontró	Relación con nuestro proyecto	Criterio
12	Trust/eudi-srv-web-trustedlist-manager-py	(búsqueda de rutas de publicación)	El gestor entrega el archivo para descargar; no se encontró una ruta que lo publique en la URL pública.	La publicación y la lectura pública parecen fuera de la aplicación; en nuestro caso las dos están dentro del registro y separadas por canal.	C4 (límite)
13	librerias/eudi-lib-android-wallet-core	wallet-core/.../registration/RegistrationCertificate.kt	Modelo del certificado de registro de un verificador (WRPRC, ETSI TS 119 475 §5.2.4), con registry_uri del registrador.	La cartera comprueba que el verificador está registrado y qué datos puede pedir: es el uso de la identidad institucional publicada.	C2
14	librerias/eudi-lib-jvm-openid4vp-kt	.../openid4vp/internal/request/RequestAuthenticator.kt	El verificador se identifica con un prefijo de client_id: DID, X.509 (SAN DNS o hash), attestation de verificador, URI de redirección o preregistrado.	Una entidad institucional puede identificarse por DID (como en nuestro registro) o por certificado.	C1
15	librerias/eudi-lib-android-wallet-core	wallet-core/.../trust/ (EtsiTrustProvider, EtsiReaderTrustStore, LoteJwtVerifier)	La cartera confía en emisores y lectores mediante listas ETSI (LoTL y LoTE).	Es el consumidor final de las listas que produce el gestor analizado.	C1

4. Aplicación a los criterios de aceptación de la ERSO 006

Para cada criterio: lo que exige el PDF de la ERSO, dónde está nuestra evidencia y qué hallazgos externos se le aplican.

Criterio 1. El DID Document institucional se sirve por HTTPS y es resoluble.

Evidencia que pide la ERSO	Lectura desde la URL pública.
Nuestra evidencia	INFORME-FINAL-ERSO-2026-006 §18
Hallazgos aplicables	#5 (Trust/eudi-srv-web-trustedlist-manager-py); #6 (Issuer/eudi-srv-pid-issuer); #7 (Verifier/eudi-wallet-rfcs); #14 (librerias/eudi-lib-jvm-openid4vp-kt); #15 (librerias/eudi-lib-android-wallet-core)
Qué aporta el análisis	Las listas de confianza se publican para lectura y la especificación de confianza admite el DID como forma de identificar a un proveedor; el emisor externo se identifica por certificado.

Criterio 2. La escritura está autenticada y trazada, limitada al namespace de la entidad.

Evidencia que pide la ERSO	Registro de la operación.
Nuestra evidencia	INFORME-FINAL-ERSO-2026-006 §19
Hallazgos aplicables	#1 (Wallet/av-app-android-wallet-ui); #2 (Issuer y Trust/eudi-srv-web-relyingparty-registration-py); #3 (Issuer y Trust/eudi-srv-web-relyingparty-registration-py); #4 (Trust/eudi-srv-web-trustedlist-manager-py); #8 (Trust/eudi-srv-web-trustedlist-manager-py); #11 (Trust/eudi-srv-web-trustedlist-manager-py); #13 (librerias/eudi-lib-android-wallet-core)
Qué aporta el análisis	Criterio con más material: el único registro externo no autentica las escrituras (contraste), mientras que el registro de entidades y el gestor de listas de confianza aplican autenticación y alcance por rol. Además, el gestor de listas limita por rol y se autentica con una credencial PID.

Criterio 3. El documento no expone material de claves privadas ni datos civiles.

Evidencia que pide la ERSO	Revisión del contenido.
Nuestra evidencia	INFORME-FINAL-ERSO-2026-006 §20
Hallazgos aplicables	Ninguno
Qué aporta el análisis	No se encontró nada aplicable en los proyectos externos.

Criterio 4. La evidencia de publicación (versión, hash y URL pública) queda registrada.

Evidencia que pide la ERSO	Registro de publicación.
Nuestra evidencia	INFORME-FINAL-ERSO-2026-006 §21
Hallazgos aplicables	#9 (Trust/eudi-srv-web-trustedlist-manager-py); #10 (Trust/eudi-srv-web-trustedlist-manager-py); #12 (Trust/eudi-srv-web-trustedlist-manager-py)
Qué aporta el análisis	Lo más cercano es la firma de las listas de confianza; no se halló un registro de publicación con versión, hash y URL. El gestor de listas muestra hash previo a la firma y huella del certificado, pero no versión ni URL persistidas.

5. Diferencias de diseño frente a nuestro proyecto

Tema	Proyectos externos	Nuestro proyecto
Identidad de la entidad	Certificado emitido por una CA	DID Document en un espacio reservado
Autenticación de escritura	Credencial PID y certificados	mTLS + OAuth2 client credentials + prueba de posesión
Alcance por entidad	Roles (TSL, LoTL)	Espacios entidades/... con un único dueño
Lectura pública	Lista firmada que se descarga	GET */did.json por un canal separado
Evidencia de publicación	Firma de la lista	Operación con versión, hash y URL; auditoría inalterable
Quién firma lo publicado	El servicio con su certificado (listas de confianza)	La entidad, con la clave de su propio DID

6. Qué aprender y qué hacer con esto

- El hallazgo de Wallet/av-app-android-wallet-ui es una buena prueba por contraste: muestra qué falta cuando el registro no autentica; sirve como argumento en la defensa del criterio 2.
- Issuer y Trust/eudi-srv-web-relyingparty-registration-py es la referencia para explicar cómo el ecosistema EUDI resuelve "quién puede registrarse" con certificados.
- Posible mejora: alinear nuestra reserva de espacios con un registro formal de entidades (como la cadena ley → entidad → proveedor).

- Análisis del gestor de listas de confianza: su valor está en **firmar todo el artefacto**; el nuestro, en **autenticar cada escritura y confirmar la publicación**. Ambos modelos se complementan.
- Idea a evaluar: registrar versión y URL de cada publicación también en el gestor, como hace nuestro registro (criterio 4).

7. Límites de este informe

- Todo proviene de **lectura de código**; el comportamiento real no se verificó ejecutando.
- Se citan archivos y, cuando se anotó, números de línea (con ~ si son aproximados); las versiones de los proyectos son las que había en disco el 2 de octubre de 2026.
- "No encontré" significa que las búsquedas realizadas no lo hallaron, no que no exista en ninguna parte del código.
- Los proyectos de referencia EUDI se declaran a sí mismos como versiones de desarrollo no aptas para producción.